

THREAT ADVISORY



**VULNERABILITY
REPORT**

**Did Patch Tuesday address the zero-day flaw in
Microsoft Exchange?**

Date of Publication

October 12, 2022

Admiralty Code

A1

TA Number

TA2022220

Summary

Microsoft addresses two new zero-day vulnerabilities tracked under CVE-2022-41033, an Elevation of Privilege vulnerability exploited in the wild. CVE-2022-41043 is an Information Disclosure vulnerability was publicly disclosed. Microsoft has not released security updates for two actively exploited zero-day vulnerabilities dubbed to ProxyNotShell.

⚙️ CVEs Table

CVE	NAME	PATCH
CVE-2022-41033	Windows COM+ Event System Service Elevation of Privilege Vulnerability	✓
CVE-2022-41043	Microsoft Office Information Disclosure Vulnerability	✓
CVE-2022-37968	Azure Arc-enabled Kubernetes cluster Connect Elevation of Privilege Vulnerability	✓
CVE-2022-41038	Microsoft SharePoint Server Remote Code Execution Vulnerability	✓
CVE-2022-38053	Microsoft SharePoint Server Remote Code Execution Vulnerability	✓
CVE-2022-41036	Microsoft SharePoint Server Remote Code Execution Vulnerability	✓

CVE	NAME	PATCH
CVE-2022-37976	Active Directory Certificate Services Elevation of Privilege Vulnerability	✓
CVE-2022-37979	Windows Hyper-V Elevation of Privilege Vulnerability	✓
CVE-2022-22035	Windows Point-to-Point Tunneling Protocol Remote Code Execution Vulnerability	✓
CVE-2022-38000	Windows Point-to-Point Tunneling Protocol Remote Code Execution Vulnerability	✓
CVE-2022-41081	Windows Point-to-Point Tunneling Protocol Remote Code Execution Vulnerability	✓
CVE-2022-38048	Microsoft Office Remote Code Execution Vulnerability	✓
CVE-2022-37988	Windows Kernel Elevation of Privilege Vulnerability	✓

Potential MITRE ATT&CK TTPs

TA0004 Privilege Escalation	T1574 Hijack Execution Flow	T1548 Abuse Elevation Control Mechanism	T1546 Event Triggered Execution
T1068 Exploitation for Privilege Escalation	TA0043 Reconnaissance	T1592 Gather Victim Host Information	TA0003 Persistence
T1543 Create or Modify System Process	T1547 Boot or Logon Autostart Execution	TA0001 Initial Access	T1190 Exploit Public-Facing Application
TA0008 Lateral Movement	T1210 Exploitation of Remote Services		

Technical Details

#1

The Tuesday patch addressed the zero-day (CVE-2022-41033) that has been exploited in the wild and compromised the COM+ Event System Service. An authenticated attacker could exploit this vulnerability to gain SYSTEM privileges on a susceptible device.

#2

Following that was (CVE-2022-41043), a publicly revealed Microsoft Office information disclosure vulnerability affecting Microsoft Office for Mac. Local access to the host is required for successful exploitation of this issue. Several critical privilege escalation issues were discovered in Azure Arc-enabled Kubernetes cluster (CVE-2022-37968), Windows Hyper-V (CVE-2022-37979), and Windows Kernel (CVE-2022-37988)

#3

Microsoft SharePoint Server has many Remote Code Execution vulnerabilities. The most severe, CVE-2022-41038, when exploited, could allow a SharePoint-authenticated attacker to execute arbitrary code on the server if the account has "Manage List" permissions. This advisory addresses 13 CVEs.

Vulnerability Details

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-41033	Windows: 7 - 11 21H2 & Windows Server: 2008 - 2022 20H2	cpe:2.3:o:microsoft:windows:11.*.*.*.*.*	CWE-119
CVE-2022-41043	Microsoft Office LTSC 2021: 2021 for Mac & Microsoft Office: 2019 for Mac	cpe:2.3:a:microsoft:microsoft_office_ltsc_2021:2021:for Mac:*.*.*.*.*	CWE-200
CVE-2022-37968	Azure Stack Edge: All versions & Azure Arc-enabled Kubernetes cluster: 1.5.8 - 1.8.11	cpe:2.3:a:microsoft:azure_stack_edge:*.*.*.*.*	CWE-264

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-41038	Microsoft SharePoint Server Subscription Edition: All versions, Microsoft SharePoint Server: 2019, Microsoft SharePoint Foundation: 2013 Service Pack 1 & Microsoft SharePoint Enterprise Server: 2013 Service Pack 1 – 2016	cpe:2.3:a:microsoft:microsoft_sharepoint_server_subscription_edition:*:*:*:*:*:*	CWE-20
CVE-2022-38053	Microsoft SharePoint Server Subscription Edition: All versions, Microsoft SharePoint Server: 2019, Microsoft SharePoint Foundation: 2013 Service Pack 1 & Microsoft SharePoint Enterprise Server: 2013 Service Pack 1 – 2016	cpe:2.3:a:microsoft:microsoft_sharepoint_server_subscription_edition:*:*:*:*:*:*	CWE-20
CVE-2022-41036	Microsoft SharePoint Server Subscription Edition: All versions, Microsoft SharePoint Server: 2019, Microsoft SharePoint Foundation: 2013 Service Pack 1 & Microsoft SharePoint Enterprise Server: 2013 Service Pack 1 – 2016	cpe:2.3:a:microsoft:microsoft_sharepoint_server_subscription_edition:*:*:*:*:*:*	CWE-20
CVE-2022-37976	Windows Server: 2003 - 2022 20H2	cpe:2.3:o:microsoft:windows_server:2022:20H2:*:*:*:*:*	CWE-264
CVE-2022-37979	Windows Server: 2003 - 2022 20H2 & Windows: 7 – XP	cpe:2.3:o:microsoft:windows_server:2022:20H2:*:*:*:*:*	CWE-362
CVE-2022-22035	Windows Server: 2003 - 2022 20H2 & Windows: 7 – XP	cpe:2.3:o:microsoft:windows_server:2022:20H2:*:*:*:*:*	CWE-362
CVE-2022-38000	Windows Server: 2003 - 2022 20H2 & Windows: 7 – XP	cpe:2.3:o:microsoft:windows_server:2022:20H2:*:*:*:*:*	CWE-362

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-41081	Windows Server: 2003 - 2022 20H2 & Windows: 7 – XP	cpe:2.3:o:microsoft:windows_server:2022:20H2:*.*.*.*.*	CWE-362
CVE-2022-38048	Microsoft Office LTSC 2021: 32 bit editions - 2021 for Mac, Microsoft Office: 2013 RT Service Pack 1 - 2019 for Mac & Microsoft 365 Apps for Enterprise: 32-bit Systems - 64-bit Systems	cpe:2.3:a:microsoft:microsoft_office_ltsc_2021:2021:for Mac:*.*.*.*.*	CWE-20
CVE-2022-37988	Windows Server: 2003 - 2022 20H2 & Windows: 7 – XP	cpe:2.3:o:microsoft:windows_server:2022:20H2:*.*.*.*.*	CWE-264

Patch Links

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-41033>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-41043>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-37968>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-41038>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-38053>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-41036>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-37976>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-37979>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-22035>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-38000>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-41081>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-38048>

<https://msrc.microsoft.com/update-guide/en-US/vulnerability/CVE-2022-37988>

References

<https://msrc.microsoft.com/update-guide/releaseNote/2022-Oct>

What Next?

Book a free demo with **HivePro Uni5** to check your exposure to this advisory. HivePro Uni5 is a Continuous Threat Exposure Management Solution that proactively reduces an organization's attack surface before it gets exploited.



At Hive Pro we take a long hard look at your vulnerabilities so you can bolster your defenses and fine-tune your offensive cybersecurity tactics.

REPORT GENERATED ON

October 12, 2022 • 6:15 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com